

Chapitre 12

La gestion du risque tiers

Feuille d'exercices

Jaouad Madkour

Faculté d'Économie et de Gestion de Tanger
Exercices et corrigés · Risque opérationnel et résilience

1 Exercices du chapitre

Exercice 1 — Le périmètre du risque tiers et son statut taxonomique

- (a) Le cours définit la gestion du risque tiers comme « l'ensemble du processus par lequel un établissement identifie, évalue et maîtrise les risques associés à ses relations avec des prestataires externes », et précise que « ce périmètre ne s'arrête pas au prestataire direct (le « tiers ») : il s'étend aux sous-traitants de ce prestataire (« quatrième partie ») et, potentiellement, aux sous-traitants de ces derniers (« cinquième partie ») ». Représenter cette chaîne à trois niveaux (tiers, quatrième partie, cinquième partie) et expliquer précisément, à partir du cours, pourquoi « un établissement reste exposé aux défaillances survenant à chacun de ces niveaux, même lorsqu'il n'a aucune relation contractuelle directe avec eux » : sur quel fondement un établissement peut-il être exposé à une défaillance d'une partie avec laquelle il n'a signé aucun contrat ?
- (b) Le cours indique que « dans la taxonomie de Bâle sur les pertes de risque opérationnel, le risque tiers apparaît comme une sous-catégorie de niveau 2 au sein de la gestion de l'externalisation », mais que « de nombreux établissements, ainsi que la taxonomie révisée de l'ORX, le traitent désormais comme une catégorie de niveau 1 à part entière, reflet de son importance croissante et de sa spécificité ». Expliquer ce que signifie concrètement, pour la gouvernance interne d'un établissement, le passage d'une sous-catégorie de niveau 2 (rattachée à l'externalisation) à une catégorie de niveau 1 autonome : quelles conséquences pratiques (reporting, appétence au risque dédiée, indicateurs propres) un tel changement de statut taxonomique implique-t-il généralement ?
- (c) Énumérer, dans l'ordre exact donné par le cours, les cinq étapes du cycle de vie du risque tiers selon le cadre du Shared Assessments Program, et résumer en une phrase l'objet précis de chacune.
- (d) Le cours affirme que « la présentation en cycle de vie souligne que la gestion du risque tiers ne s'arrête jamais à la signature du contrat » et que « la phase de suivi continu et la possibilité de remédiation ou de résiliation font partie intégrante du dispositif, au même titre que la sélection initiale ». Un établissement qui exécuterait scrupuleusement les trois premières étapes du cycle (décision de modèle d'affaires, évaluation/diligence raisonnable, contrats et SLA) mais négligerait les deux dernières (suivi continu, remédiation ou résiliation) aurait-il, selon cette logique, mis en œuvre une gestion du risque tiers conforme au cadre du cours ? Justifier précisément à partir de la formulation « pas une liste de contrôle ponctuelle ».

Exercice 2 — Étude de cas Capital One : migration cloud et diligence préalable

- (a) Résumer précisément les faits du cas Capital One tels que rapportés par le cours : la date de la révélation, le nombre approximatif de personnes affectées, l'identité de l'attaquante, la nature exacte de la faille exploitée (mauvaise configuration d'un WAF, attaque SSRF), et l'infrastructure sur laquelle cette faille se trouvait.
- (b) Le cours précise que l'amende de 80 millions USD infligée par l'OCC a été « motivée non par l'attaque elle-même mais par l'insuffisance des processus d'évaluation des risques mis en œuvre **avant** la migration vers l'infrastructure cloud publique », le régulateur ayant jugé que « la banque n'avait pas correctement évalué les risques inhérents à ce type d'architecture ni mis en place les contrôles compensatoires appropriés ». Expliquer précisément la distinction, implicite dans cette motivation, entre sanctionner un *incident* et sanctionner un *processus* : en quoi le montant de la sanction aurait-il pu être identique, selon cette logique, même si l'attaque SSRF n'avait jamais eu lieu ?
- (c) Le cours conclut que « recourir à un prestataire technologique de premier plan comme AWS ne dispense pas l'établissement d'évaluer et de maîtriser lui-même les risques de configuration et d'architecture de son propre environnement hébergé » et que « la compétence du tiers ne remplace pas la diligence raisonnable de son client ». Expliquer pourquoi la réputation et la compétence technique reconnues d'un fournisseur cloud comme AWS ne constituent pas, en

elles-mêmes, un facteur qui devrait réduire l'intensité de la diligence raisonnable exercée par son client, au sens de ce chapitre.

- (d) À quelle étape précise du cycle en cinq phases identifié à l'exercice 1(c) la défaillance de Capital One se rattache-t-elle le plus directement ? Justifier en montrant que l'insuffisance pointée par l'OCC porte sur un moment *antérieur* à l'engagement effectif dans l'architecture cloud, et non sur une défaillance de surveillance ultérieure.

Exercice 3 — Étude de cas Morgan Stanley : répétition et angle mort du décommissionnement

- (a) Résumer précisément les faits du cas Morgan Stanley tels que rapportés par le cours : le montant de la sanction de l'OCC, sa motivation générale, les deux dates des incidents, la nature de l'activité concernée (décommissionnement de serveurs de gestion de patrimoine), et la défaillance technique commune aux deux incidents (effacement ou destruction non garantis des données clients).
- (b) Le cours affirme que « ce qui distingue le cas Morgan Stanley, c'est la récurrence » et qu'« un premier incident en 2016 aurait dû déclencher une révision en profondeur des procédures de décommissionnement ; sa répétition en 2019 a été interprétée par le régulateur comme la preuve que les enseignements du premier incident n'avaient pas été tirés — un manquement à la surveillance continue, pas seulement à un contrôle ponctuel ». Expliquer précisément pourquoi, selon cette lecture du régulateur, le second incident de 2019 constitue une faute plus grave que ne l'aurait été un incident isolé et unique en 2019 sans précédent en 2016 : qu'est-ce que la répétition, à elle seule, révèle que l'incident initial de 2016 ne révélait pas ?
- (c) Le cours qualifie le décommissionnement d'« angle mort classique du risque tiers », affirmant que « la fin de vie d'un actif ou d'une relation tierce — retrait de matériel, résiliation de contrat, migration vers un nouveau prestataire — est souvent moins scrutée que sa mise en place » et que « les moments de transition [...] concentrent un risque disproportionné par rapport à l'attention qui leur est généralement accordée ». Pourquoi, structurellement, une organisation a-t-elle spontanément tendance à consacrer moins d'attention à la fin d'une relation tierce qu'à son commencement ? Formuler une explication précise, en s'appuyant sur la nature même d'une transition (matériel qui change de statut, responsabilités qui se transfèrent, attention organisationnelle qui se porte déjà sur la relation suivante).
- (d) Comparer précisément la nature de la défaillance de Morgan Stanley à celle de Capital One (exercice 2) en les rattachant chacune à l'étape ou aux étapes du cycle en cinq phases qu'elles illustrent le mieux : la défaillance de Capital One relève-t-elle du même moment du cycle que celle de Morgan Stanley, ou d'un moment distinct ? Conclure en expliquant en quoi ces deux moments distincts — l'un en amont de l'engagement, l'autre en aval, à la sortie de la relation — illustrent ensemble l'affirmation de la synthèse du cours selon laquelle « les sanctions les plus lourdes sanctionnent moins l'incident lui-même que l'absence de dispositif de contrôle robuste en amont ».

2 Exercice cumulatif (chapitres 12, 11, 10, 9, 8)

Exercice 4 — Le risque tiers à la lumière des quatre chapitres précédents

- (a) Le chapitre 11 exige, comme premier axe de la diligence raisonnable envers un prestataire, l'examen de « sa réputation et sa stratégie d'affaires, sa situation financière, et ses contrôles internes et opérationnels — y compris, le cas échéant, sa propre diligence sur ses sous-traitants (le « risque de quatrième partie ») », une mention isolée, entre parenthèses, au sein d'une liste plus large. Ce chapitre reprend cette même expression — « quatrième partie » — mais en fait le second maillon d'une chaîne structurée à trois niveaux (tiers, quatrième partie, cinquième partie), dotée de son propre cycle de vie en cinq étapes et illustrée par deux études de cas sanctionnées à hauteur de plusieurs dizaines de millions de dollars chacune. Montrer que la définition de ce

chapitre — « un établissement reste exposé aux défaillances survenant à chacun de ces niveaux, même lorsqu'il n'a aucune relation contractuelle directe avec eux » — ne fait, au fond, que systématiser et prolonger d'un cran supplémentaire (la cinquième partie) ce que le chapitre 11 mentionnait déjà en germe pour la seule quatrième partie. Qu'est-ce que ce chapitre ajoute précisément, au-delà de cette généralisation, que le chapitre 11 ne fournissait pas : quel cadre d'analyse (cycle de vie, statut taxonomique propre) et quelles illustrations concrètes (Capital One, Morgan Stanley) manquaient à la seule mention entre parenthèses du chapitre 11 ?

- (b) Le chapitre 10 rapporte que, dans le cas USAA, le département conformité LCB-FT était « significativement sous-effectif, comblé par des sous-traitants dont les qualifications n'avaient pas été vérifiées », une défaillance ayant contribué à une sanction de 140 millions USD motivée par la « qualité du dispositif de contrôle », non par des faits avérés de blanchiment. Ce chapitre illustre, avec Capital One, une défaillance de nature comparable mais située différemment dans le cycle : une insuffisance de « diligence raisonnable » en amont de l'engagement (étape 2 du cycle de ce chapitre), portant ici non sur la vérification des qualifications d'un sous-traitant mais sur l'évaluation des risques d'une architecture cloud avant sa mise en service. Montrer que les deux cas — sous-traitants non vérifiés chez USAA, architecture cloud non évaluée chez Capital One — relèvent, au sens de ce chapitre, de la même étape défaillante du cycle de vie du risque tiers, en dépit de la nature très différente des activités concernées (conformité réglementaire contre infrastructure technique). En quoi le montant nettement supérieur de la sanction USAA (140 millions USD contre 80 millions USD pour Capital One) tient-il, ou non, à une différence de nature de la défaillance plutôt qu'à une différence de gravité ou d'ampleur des conséquences ?
- (c) Le chapitre 9 exige qu'« un système de surveillance adapté à sa taille, ses activités et sa complexité » fournisse « les alertes nécessaires à l'évaluation approfondie des transactions suspectes », et précise que « l'audit interne doit évaluer périodiquement le système de surveillance informatisé pour s'assurer qu'il est utilisé effectivement par les première et deuxième lignes de défense » — un mécanisme explicite de vérification répétée de l'effectivité d'un dispositif de contrôle. Ce chapitre attribue au cas Morgan Stanley une faute aggravée par la « récurrence », le régulateur ayant vu dans la répétition de 2019 « la preuve que les enseignements du premier incident [de 2016] n'avaient pas été tirés — un manquement à la surveillance continue, pas seulement à un contrôle ponctuel ». Montrer que l'exigence du chapitre 9 d'une évaluation périodique de l'effectivité du dispositif de surveillance — typiquement portée par l'audit interne, troisième ligne de défense — est précisément le mécanisme dont l'absence, chez Morgan Stanley entre 2016 et 2019, aurait permis d'éviter que le second incident de décommissionnement ne se reproduise à l'identique. En quoi la logique de « suivi continu » (étape 4 du cycle de ce chapitre) rejoint-elle ainsi, pour un objet différent (le décommissionnement de serveurs plutôt que la surveillance transactionnelle ML/FT), l'exigence de vérification périodique posée par le chapitre 9 ?
- (d) Le chapitre 8 attribue la brèche Equifax à cinq faiblesses interconnectées, dont « l'absence d'inventaire exhaustif des actifs informatiques », qui « a empêché les équipes de localiser et corriger Apache Struts dans le délai réglementaire de 48 heures ». Ce chapitre attribue la brèche Capital One à une « mauvaise configuration d'un pare-feu applicatif web (WAF) hébergé sur l'infrastructure cloud de Capital One », sanctionnée non pour l'attaque elle-même mais pour « l'insuffisance des processus d'évaluation des risques mis en œuvre avant la migration ». Les deux cas partagent une origine technique apparentée (une vulnérabilité de configuration ou d'inventaire non maîtrisée), mais Equifax est un cas de défaillance *interne*, sur les propres systèmes de l'entreprise, tandis que Capital One est un cas de défaillance située sur une infrastructure *tierce* (le cloud d'AWS), bien que la responsabilité en incombe, selon ce chapitre, entièrement à Capital One elle-même (« la compétence du tiers ne remplace pas la diligence raisonnable de son client »). Montrer que la leçon d'Equifax — l'absence d'inventaire exhaustif des actifs informatiques comme cause racine d'une brèche majeure — se transpose directement au cas Capital One si l'on admet qu'un établissement doit inventorier et évaluer les risques de configuration de ses actifs hébergés chez un tiers avec la même rigueur que ses actifs internes. En quel sens ce chapitre généralise-t-il ainsi, au cas particulier de l'infrastructure tierce, une exigence de maîtrise des actifs que le chapitre 8 avait établie pour le seul périmètre interne de l'établissement ?

3 Applications en sciences économiques

Exercice 5 — La chaîne tiers, quatrième partie, cinquième partie : exposition en cascade, chiffrée

Une banque confie quatre activités critiques à quatre tiers distincts. Chaque tiers sous-traite une partie de son propre volume à une quatrième partie, qui sous-traite à son tour une fraction de ce volume à une cinquième partie. Les données sont les suivantes :

Activité	Tiers	Montant (k€)	% vers 4 ^e	% 4 ^e →5 ^e
Hébergement cloud (IaaS)	A	2 400	45 %	30 %
Support informatique (help desk)	B	1 600	65 %	40 %
Traitement des données clients	C	1 000	25 %	20 %
Sécurité physique des agences	D	500	0 %	—

- Pour chaque activité, calculer le montant sous-traité par le tiers à la quatrième partie, et le montant que le tiers conserve directement (montant confié moins montant sous-traité au 4^e). Calculer ensuite le montant total confié pour l'ensemble des quatre activités.
- Pour chaque activité, calculer le montant que la quatrième partie sous-traite à son tour à une cinquième partie, et le montant que la quatrième partie conserve directement. Calculer ensuite, pour l'ensemble du portefeuille des quatre activités, le montant total conservé directement par les tiers, le montant total conservé directement par les quatrièmes parties, et le montant total atteignant la cinquième partie.
- Calculer la part du montant total du portefeuille des quatre activités qui, in fine, dépasse le seul tiers direct — c'est-à-dire qui est effectivement traité par une quatrième ou une cinquième partie. Identifier l'activité pour laquelle l'exposition à la cinquième partie est la plus élevée en valeur absolue.
- Le cours affirme qu'« un établissement reste exposé aux défaillances survenant à chacun de ces niveaux, même lorsqu'il n'a aucune relation contractuelle directe avec eux ». On suppose que la probabilité annuelle d'incident est de 2 % pour la portion traitée directement par le tiers, 5 % pour la portion traitée directement par la quatrième partie, et 9 % pour la portion atteignant la cinquième partie — une probabilité croissante à mesure que la visibilité contractuelle directe de la banque diminue — et qu'un incident, s'il survient, détruit 20 % de la valeur de la portion concernée. Pour l'activité identifiée en (c), calculer la perte attendue associée à chacun des trois niveaux (tiers, quatrième partie, cinquième partie), ainsi que la perte attendue totale de cette activité. Calculer également, pour cette même activité et en supposant l'indépendance des trois niveaux, la probabilité qu'au moins un incident survienne quelque part dans la chaîne, et l'écart, en points de pourcentage, entre cette probabilité et la seule probabilité d'incident chez le tiers direct.

Exercice 6 — Diligence préalable et effacement sécurisé : le coût attendu de sauter une étape du cycle, c

Une banque envisage deux décisions distinctes, inspirées chacune de l'une des deux études de cas du cours.

- (*Cas inspiré de Capital One.*) La banque prépare la migration d'une plateforme de données vers le cloud public. Sans évaluation préalable approfondie des risques (étape 2 du cycle du cours), la probabilité d'une violation majeure liée à une mauvaise configuration sur les trois années suivant la migration est estimée à 12 %, pour un coût attendu (amende réglementaire et remédiation) de 45 millions de dollars en cas de survenance. Une évaluation préalable approfondie coûterait 1,8 million de dollars et ramènerait cette probabilité à 2 %, sans changer le coût en cas de survenance. Calculer le coût attendu de la violation avec et sans évaluation préalable, la réduction brute du coût attendu permise par l'évaluation, et le gain net (réduction moins coût de l'évaluation).

- (b) Calculer le ratio bénéfice/coût de l'investissement dans l'évaluation préalable (réduction brute du coût attendu rapportée au coût de l'évaluation). Ce ratio est-il cohérent avec la logique de la sanction de l'OCC contre Capital One, motivée — selon le cours — par l'insuffisance des processus d'évaluation des risques *avant* la migration plutôt que par l'attaque elle-même ?
- (c) (*Cas inspiré de Morgan Stanley.*) La banque décommissionne 4000 serveurs à l'issue d'un contrat avec un prestataire d'hébergement. Un protocole d'effacement sécurisé coûte 120 dollars par serveur. Sans effacement sécurisé vérifié, la probabilité qu'un premier incident de décommissionnement (données clients récupérables) soit détecté par le régulateur est de 18 %, pour une amende moyenne de 8 millions de dollars en cas de survenance. Calculer le coût total de l'effacement sécurisé pour l'ensemble des 4000 serveurs, le coût attendu d'un premier incident en l'absence d'effacement sécurisé, et l'écart entre les deux. L'investissement préalable dans l'effacement sécurisé est-il justifié au regard de ce seul écart ?
- (d) On suppose désormais qu'un premier incident de décommissionnement s'est effectivement matérialisé (comme chez Morgan Stanley en 2016) et que la banque n'a pas corrigé sa procédure. La probabilité d'un second incident, lors d'un décommissionnement ultérieur, est alors de 50 %; parce que le cours indique qu'une répétition est interprétée par le régulateur comme la preuve que « les enseignements du premier incident n'avaient pas été tirés », l'amende du second incident est majorée de 50 % par rapport à celle du premier, à 12 millions de dollars. Une remédiation complète de la procédure de décommissionnement après le premier incident coûterait 400 000 dollars et ramènerait la probabilité du second incident à 4 %. Calculer le coût attendu de la voie « sans remédiation » (probabilité du second incident multipliée par l'amende majorée) et celui de la voie « avec remédiation » (coût de la remédiation plus probabilité réduite multipliée par l'amende majorée). Quelle voie minimise le coût attendu, et de quel montant ?